La protection des données – Le RGPD – Les actions en entreprises

Les fondamentaux de la protection des données et leur mise en œuvre – Les actions à mettre en œuvre en entreprise

Philippe NICOLAS

04/03/2026

La protection des données – Le RGPD

Plan :

1 - Le Droit de la protection des données (2 à 15)

2 - Le RGPD et la mise en œuvre des prescriptions

3 - Les actions à mettre en œuvre en entreprise

1 - Le Droit des données – Le Règlement Général sur la Protection des Données – Principes et obligations

Les fondements juridiques de la protection des données opposables en France

- En France, la protection des données personnelles est encadrée par la loi du 6 janvier 1978 dite « Informatique et libertés »
- La loi du 20 juin 2018 relative à la protection des données personnelles a modifié la loi « Informatique et Libertés » pour l'adapter aux dispositions du Règlement général sur la protection des données (RGPD), **applicable partout en Europe** depuis le **25 mai 2018** (Règlement n°2016/679 adopté le 14 avril 2016, promulgué le 27 avril 2016 par PE et Conseil et entré en vigueur le 24 mai 2016 en UE, et en France le 25 mai 2018)
- Décret n°2005-1309 du 20 octobre 2005 pris pour l'application de la loi n° 78-17 du 6 janvier 1978 relative à l'informatique, aux fichiers et aux libertés(version consolidée au 08 août 2018), enfin certaines dispositions de la loi n° 2004-575 du 21 juin 2004 pour la confiance en l'économie numérique traitent de la protection des données
- Plus récemment l'adoption du DATA Act – Règlement UE 2023/2854 du PE et du Conseil du 13/12/2023 et dont l'entrée en vigueur au 11 janvier 2024 pour une application au **12 septembre 2025** donne **une impulsion nouvelle au marché de la donnée en terme de protection des consommateurs, notamment**
- **Ce nouveau cadre juridique renforce les droits de chaque citoyen européen sur la protection de ses données personnelles et responsabilise les acteurs traitant ces données**

Le détail des dispositions du RGPD

Principe clé et article	Description
Le cadre harmonisé	Il y a désormais un seul ensemble de règles relatives à la protection des données, directement applicable dans tous les États membres de l'Union européenne, atténuant ainsi la fragmentation actuelle des lois nationales de protection des données
L'application extraterritoriale (article 3)	Le règlement s'applique aux entreprises établies en dehors de l'Union européenne qui traitent les données relatives aux activités des organisations de l'UE. Les sociétés non européennes sont également soumises au règlement dès qu'elles ciblent les résidents de l'UE par le profilage ou proposent des biens et services à des résidents européens
Le consentement « explicite » et « positif »	Les entreprises et organismes doivent donner aux citoyens davantage de contrôle sur leurs données privées, notamment via l'acceptation des cookies sur les sites internet et sur le contrôle de l'utilisation qui est faite des données que les internautes envoient dans les formulaires de contact. Par exemple, il n'est plus possible que la case "j'accepte de recevoir la newsletter" soit pré-cochée lors de l'envoi d'un formulaire de contact dans lequel l'e-mail est renseigné
Le droit à l'effacement (version allégée du droit à l'oubli) (article 17)	La personne concernée a le droit d'obtenir du responsable du traitement l'effacement, dans les meilleurs délais, de données à caractère personnel la concernant et le responsable du traitement a l'obligation d'effacer ces données à caractère personnel dans les meilleurs délais pour 6 motifs

Le détail des dispositions du RGPD

Le droit à la portabilité des données personnelles (article 20)	Les personnes concernées ont le droit de recevoir les données à caractère personnel les concernant qu'elles ont fournies à un responsable du traitement, dans un format structuré, couramment utilisé et lisible par machine, et ont le droit de transmettre ces données à un autre responsable du traitement. Lorsque la personne concernée exerce son droit à la portabilité des données en application du paragraphe 1, elle a le droit d'obtenir que les données à caractère personnel soient transmises directement d'un responsable du traitement à un autre, lorsque cela est techniquement possible
Le profilage (article 22)	Toute personne a le droit de ne pas faire l'objet d'une décision fondée exclusivement sur un traitement automatisé, y compris le profilage, produisant des effets juridiques la concernant ou l'affectant de manière significative de façon similaire
Les principes de « protection des données dès la conception » et de « sécurité par défaut » (article 25)	Le règlement européen définit le principe de « protection des données dès la conception » (en anglais : Privacy by design) qui impose aux organisations de prendre en compte des exigences relatives à la protection des données personnelles dès la conception des produits, services et systèmes exploitant des données à caractère personnel. De plus, le règlement consacre la nouvelle règle de la « sécurité par défaut » qui impose à toute organisation de disposer d'un système d'information sécurisé
Les notifications en cas de fuite de données (article 33)	Les entreprises et les organismes sont tenus de notifier dès que possible l'autorité nationale de protection en cas de violations graves de données afin que les utilisateurs puissent prendre des mesures appropriées

Le détail des dispositions du RGPD

La possibilité de désigner un délégué à la protection des données (article 37-1)	Cette nomination est obligatoire lorsque : • « le traitement est effectué par une autorité publique ou un organisme public, à l'exception des juridictions agissant dans l'exercice de leur fonction juridictionnelle » (art. 37-1.a) ; • « les activités de base du responsable du traitement ou du sous-traitant consistent en des opérations de traitement qui, du fait de leur nature, de leur portée et/ou de leurs finalités, exigent un suivi régulier et systématique à grande échelle des personnes concernées » (art. 37-1.b) ; • « les activités de base du responsable du traitement ou du sous-traitant consistent en un traitement à grande échelle de catégories particulières de données visées à l'article 9 et de données à caractère personnel relatives à des condamnations pénales et à des infractions visées à l'article 10. » (art. 37-1.c) Sont ainsi visées les données « sensibles » dont notamment celles relatives à l'état de santé des personnes, leur état de fragilité, ou encore les données à caractère personnel relatives aux infractions et condamnations
Les missions du délégué à la protection des données	Le délégué à la protection des données doit être associé à toutes les questions de protection des données à caractère personnel. Ses principales missions sont de contrôler le respect du règlement, de conseiller le responsable des traitements sur son application et de faire office de point de contact avec l'autorité de contrôle, de répondre aux sollicitations de personnes qui souhaitent exercer leurs droits

Le détail des dispositions du RGPD

La possibilité de désigner un délégué à la protection des données (article 37-1)	Cette nomination est obligatoire lorsque : • « le traitement est effectué par une autorité publique ou un organisme public, à l'exception des juridictions agissant dans l'exercice de leur fonction juridictionnelle » (art. 37-1.a) ; • « les activités de base du responsable du traitement ou du sous-traitant consistent en des opérations de traitement qui, du fait de leur nature, de leur portée et/ou de leurs finalités, exigent un suivi régulier et systématique à grande échelle des personnes concernées » (art. 37-1.b) ; • « les activités de base du responsable du traitement ou du sous-traitant consistent en un traitement à grande échelle de catégories particulières de données visées à l'article 9 et de données à caractère personnel relatives à des condamnations pénales et à des infractions visées à l'article 10. » (art. 37-1.c) Sont ainsi visées les données « sensibles » dont notamment celles relatives à l'état de santé des personnes, leur état de fragilité, ou encore les données à caractère personnel relatives aux infractions et condamnations
Les missions du délégué à la protection des données	Le délégué à la protection des données doit être associé à toutes les questions de protection des données à caractère personnel. Ses principales missions sont de contrôler le respect du règlement, de conseiller le responsable des traitements sur son application et de faire office de point de contact avec l'autorité de contrôle, de répondre aux sollicitations de personnes qui souhaitent exercer leurs droits

Réglementation applicable en matière de protection des données à caractère personnel

Règlement Général sur la Protection des Données (RGPD)

Objectif du règlement: refonte de l'ensemble du cadre juridique européen des données issues de la Directive 95-46 du 24 octobre 1995

Application directe du RGPD dans tous les Etats membres de l'UE

Entrée en application le 25 mai 2018

Loi Informatique et Libertés

La loi n° 2018-493 du 20 juin 2018 a été adoptée pour mettre en conformité la loi n°78-17 du 6 janvier 1978 dite « Informatique et Libertés » (LIL) au RGPD.

Puis, une ordonnance du 12 décembre 2018 a achevé, au niveau législatif, la mise en conformité du droit national avec le RGPD.

CNIL.

La **Commission nationale de l'informatique et des libertés (CNIL)** est l'autorité française en matière des données personnelles. Elle accompagne et contrôle la mise en conformité des entreprises, organismes publics et associations.

La CNIL publie régulièrement des ressources tels que des lignes directrices, des fiches informatives ainsi que des outils permettant de vérifier sa conformité au RGPD. Ces ressources sont disponibles en libre accès sur le site web de la CNIL:

- https://www.cnil.fr/fr/les-outils-de-la-conformite
- https://www.cnil.fr/les-decisions-de-la-cnil
- https://www.cnil.fr/fr/fiches-pratiques

Réglementation applicable en matière de protection des données à caractère personnel – Champ d'application

Le champ d'application de la réglementation en matière de données a été élargi par le RGPD :

Champ matériel	Champ territorial
Le RGPD s'applique aux : ▷ Traitements de données personnelles : *(sans qu'il y ait de distinction selon que le RT est une personne physique ou morale)* ↳ Automatisés en tout ou partie ↳ Non-automatisés, appelés à figurer dans un fichier **Sont exclus :** ▷ Les activités personnelles (traitements réalisés par des personnes physiques dans le cadre d'une activité strictement personnelle ou domestique)	**Le RGPD s'applique à tous les organismes publics ou privés, quelque soient leur taille ou secteur d'activité (notamment aux entreprises, associations, collectivités) qui :** ▷ Ont un établissement sur le territoire de l'UE Par ex. une usine française, des bureaux Par ex. un site web édité par un organisme français ▷ RT et aux ST non établis en UE mais dont l'activité cible des personnes qui se trouvent dans l'UE Par ex. un site web à destination des personnes situées au sein de l'UE

Traitement de Données Personnelles : de quoi parle-t-on ?

Traitement de Données Personnelles : de quoi parle-t-on ?

EXEMPLES DE DONNEES PERSONNELLES :

- Nom/ prénom, adresse et coordonnées (téléphone, email etc.)
- Statut marital, informations relatives aux enfants (nom, âge, nombre etc.)
- Données bancaires
- Images/ films / vidéosurveillance, enregistrements téléphoniques
- Données de connexion (login, identifiants, mots de passe), cookies, historique de navigation, adresse IP
- Numéro de sécurité sociale
- Données relatives aux opinions religieuses, syndicales, politiques ou à l'orientation sexuelle, données relatives à la santé
- Numéro de badge / logs de passage en badgeuse
- Données biométriques (empreintes digitale, iris, mensurations etc.)
- Données relatives à des infractions
- Données relatives à la santé (pathologie, maladie, blessure etc.)

Traitement de Données Personnelles : de quoi parle-t-on ?

Données personnelles d'un contact professionnel (ex : au sein de la personne morale)

Facture

Données personnelles d'un candidat : nom, prénom, coordonnées mais également diplômes et expériences professionnelles

CV d'un candidat

Données personnelles des visiteurs d'un site, salariés du site industriel : image des personnes

Video-surveillance

Les principaux acteurs du RGPD

Origine raciale ou ethnique

Appartenance **syndicale**

Opinions **politiques**

Opinions **religieuses**

Opinions **philosophiques**

Orientation et vie **sexuelle**

Données de **santé**

Données **biométriques**

Données **génétiques**

Infractions, condamnations

Les principaux acteurs du RGPD

Quelques notions clés…

OUI / NON

Identifier des données à caractère personnel	Identifier des traitements
❑ Numéro de téléphone de prospect	❑ Suivi d'un candidat au recrutement/CV
❑ Plaque d'immatriculation	❑ Facturation
❑ Numéro de poste d'un salarié	❑ Tracking par cookies sur site internet
❑ Adresse IP	❑ Listing papier des employés
❑ Relevé des compteurs EDF de l'entreprise	❑ Organigramme
❑ Badge d'accès aux locaux	❑ Dossier salarié
❑ Adresse email professionnelle	❑ Liste de courses
❑ Relevé de consommation au restaurant d'entreprise	❑ Vidéosurveillance
❑ Mensurations	❑ Géolocalisation des véhicules
❑ Chiffre d'affaires	

2 - Le Droit des données – La mise en œuvre du Règlement Général sur la Protection des Données

Les principaux acteurs du RGPD

Personne concernée
Personne dont les données font l'objet du traitement

Responsable(s) de traitement conjoints
Entité qui détermine conjointement avec le responsable de traitement les finalités et/ou les moyens du traitement

Responsable(s) de traitement
Entité qui détermine les finalités et les moyens du traitement

Finalités = objectifs du traitement

Contrat
- Donne les instructions au ST
- Agit dans les limites fixées par le RT

Sous-traitant
Toute personne qui traite des données pour le compte du responsable de traitement

Délégué à la protection des données « DPO »
Chef d'orchestre de la conformité RGPD. Il a notamment pour rôle :
- d'informer et de conseiller l'organisme
- de contrôler le respect du règlement et du droit national en matière de protection des données
- de coopérer avec la CNIL et d'être son point de contact.

Destinataires
Personne mentionnée comme telle et habilitée à recevoir communication des données à caractère personnel

+ CNIL. COMMISSION NATIONALE INFORMATIQUE & LIBERTÉS

Quelques notions clés…

Donnée à caractère personnel	Toute information concernant une personne physique identifiée ou identifiable
Traitement	Toute opération physique ou numérique appliquée à des données personnelles telle que la collecte, l'enregistrement, ou la communication
Personne concernée	Personne physique à laquelle se rapportent les données qui font l'objet d'un traitement
Responsable de traitement	La personne physique ou morale qui décide des finalités et des moyens du traitement de données personnelles
Sous Traitant	La personne physique ou morale qui traite les données pour le compte et selon les instructions du Responsable de Traitement
Finalité	But / objet du traitement (par exemple : gestion de la formation, gestion de la communication externe, gestion des candidatures, etc.)
Données sensibles	Données personnelles révélant les origines raciales ou ethniques, les opinions politiques, philosophiques, ou religieuses, l'appartenance syndicale, la santé ou la vie sexuelle de la personne concernée

Obligations RGPD du responsable de traitement

Principes fondamentaux de la protection de données personnelles

➔ « ***Accountability*** » : respecter les principes du RGPD et être également en mesure de le démontrer aux autorités de contrôle (la CNIL en France)

Licéité

Mise en oeuvre d'un traitement de données personnelles sur la base d'un fondement prévu par le RGPD, à savoir principalement :

- Le consentement
- L'exécution d'un contrat
- Une obligation légale
- L'intérêt légitime

Minimisation et exactitude des données

Collecte de données adéquates, pertinentes et limitées aux finalités du traitement
Collecte de données exactes et tenues à jour

Limitation des finalités

Collecte de données pour des finalités déterminées, explicites et légitimes, et ne pas être traitées ultérieurement d'une manière incompatible avec ces finalités

Loyauté et transparence

Information des Personnes concernées quant aux traitements mis en oeuvre et gestion de l'exercice des droits des Personnes concernées

Limitation de la conservation

Limitation de la durée de conservation des données pour une durée necessaire à la réalisation des finalités du traitement.
➔ Durée prévue par la loi ou objet d'une analyse en interne en fonction des besoins

Intégrité et confidentialité

Garantie de la sécurité et la confidentialité des données personnelles (et limitation des accès aux données personnelles, notification des violations de données personnelles)

Obligations RGPD du responsable de traitement

Boite à outils de *l'accountability*

Registre des traitements

- **Obligation de tenir un registre des traitements**
- **Mentions obligatoires :**
  1. Noms et coordonnées du DPO et du RT
  2. Finalités
  3. Données traitées
  4. Personnes concernées
  5. Destinataires
  6. Transfert de données
  7. Durée de conservation
  8. Mesures de sécurité

Encadrement des relations avec les tiers

- Nécessité d'identifier et d'encadrer les relations avec les Sous-traitants (Article 38 RGPD - Garanties suffisantes du Sous-traitant)
- Nécessité d'identifier et d'encadrer les relations entre Responsables conjoints (Article 26 RGPD - Répartition de responsabilité)

Outils et documentation

- **Outils et procédures pour gérer, piloter, former et contrôler**

  Quelques exemples :
  - Politique en matière de durée de conservation
  - Procédure de gestion des violations de données
  - Mentions d'information
  - .....

Analyse d'Impact sur la Protection des Données (AIPD)

- Examen approfondi d'un traitement de données susceptible d'engendrer un « ***risque élevé pour les droits et libertés*** »
- Appréciation au regard par ex. des critères du CEPD et des listes de la CNIL
- En cas de risque élevé, consultation de la CNIL nécessaire

Encadrement des transfert hors UE

- Nécessité d'identifier et encadrer les transferts de données hors UE :
  - Transfert vers des pays dont le régime présente un **niveau adéquat de protection des données**
  - Ou **garantie adéquate** à mettre en place (CCT - BCR)

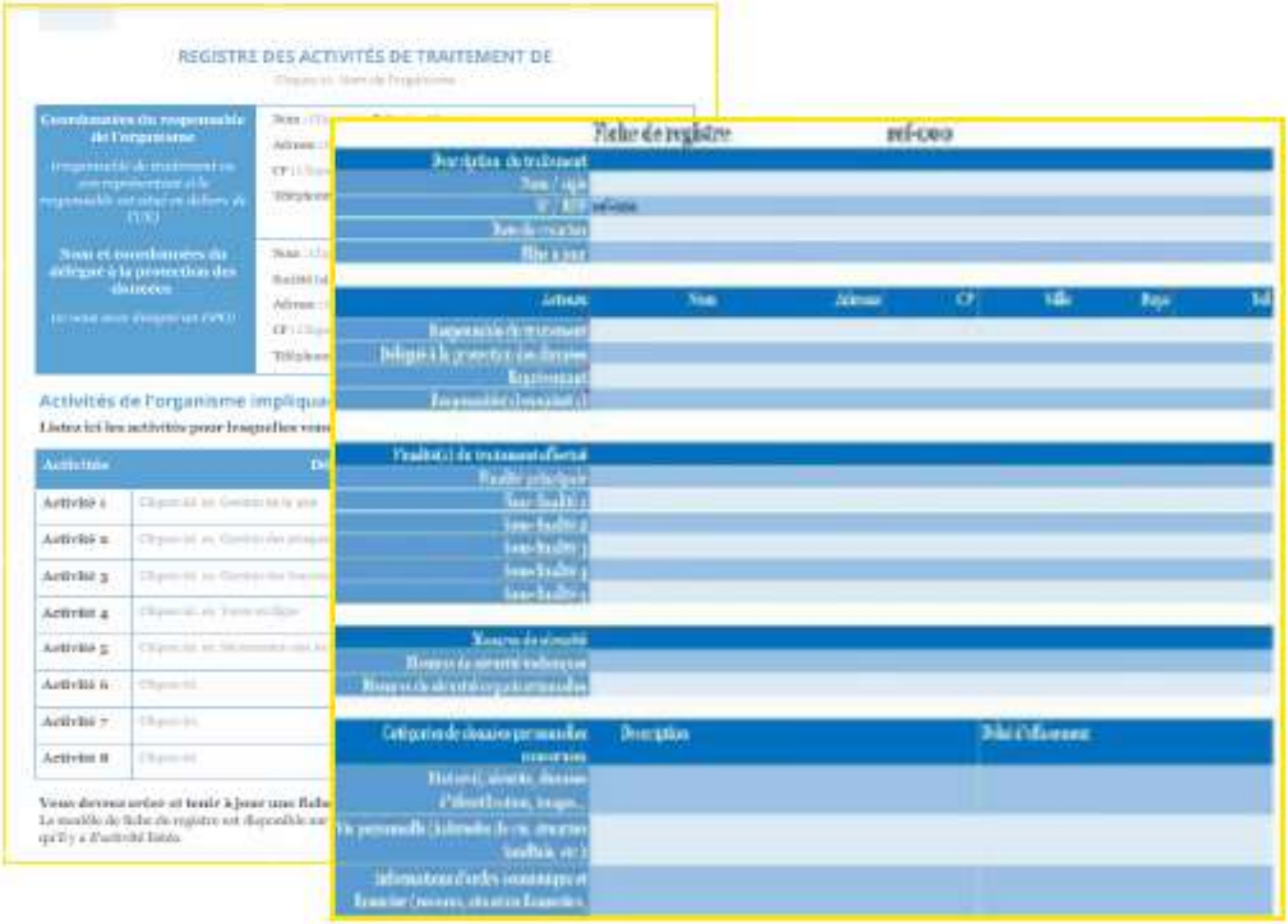
UNIVERSITÉ SAVOIE MONT BLANC tétras CSM HAUTE-SAVOIE

Registre des traitements

Pour faciliter la tenue du registre, la CNIL propose un modèle de registre de base destiné à répondre aux besoins les plus courants en matière de traitements de données.

Ce document vise à recenser les traitements de données personnelles mis en œuvre dans votre organisme en tant que responsable de traitement

https://www.cnil.fr/sites/default/files/atoms/files/registre-traitement-simplifie.ods



Obligations RGPD du responsable de traitement

Désignation d'un Délégué à la Protection des Données (DPO) ?

Désignation obligatoire

En cas de :

- Autorité ou entité publique
- Activités principales qui impliquent des traitements induisant un « *contrôle régulier et systématique des personnes à grande échelle* »
- Traitements « *à grande échelle des catégories particulières de données (données sensibles…) et des données relatives à des condamnations et infractions* »

Modalités

- UN DPO unique au niveau du groupe
- Personnel ou contrat de prestation de service

Missions

- Informer et conseiller
- Contrôler la conformité des politiques internes (sensibilisation du personnel, audit…)
- Superviser la réalisation des PIA
- Point de contact avec les autorités

Fonction

- Indépendance
- Absence de conflits d'intérêts
- Secret professionnel / obligation de confidentialité

Vous répondez à ces prérequis ?

> Commencez votre désignation

CNIL.
COMMISSION NATIONALE INFORMATIQUE & LIBERTÉS

UNIVERSITÉ SAVOIE MONT BLANC · tétras · CSM HAUTE-SAVOIE

Désignation d'un Délégué à la Protection des Données (DPO) ?

dpo@xxxx.com

Demandes d'exercice des droits :

- réponse sous 1 mois (jusqu'à 3 mois en cas de demande complexe);
- Gratuité

Exceptions:

- Droits de tiers, droits de l'entreprise;
- Demande excessive, répétitive.

Documentation de pilotage de la conformité RGPD

- **Outils et procédures pour gérer, piloter, former et contrôler**

Quelques exemples :

- Politique en matière de durée de conservation
- Procédure de gestion des violations de données
- Mentions d'information
- .....

Documentation de pilotage de la conformité RGPD

Exemple de contenu d'une procédure RGPD

Conserver les données à caractère personnel pendant une durée limitée

Une fois collectées, les données ne peuvent être conservées que pendant la <u>durée nécessaire à la réalisation de l'objectif</u> pour lequel elles sont collectées.

1) Durée d'utilité
2) Dispositions légales ou réglementaires
3) Délibérations de la CNIL

Appliquées au processus de recrutement et de départ d'un salarié:

Recrutement → Embauche → Départ

Fichiers de recrutement	En cas d'issue négative à une candidature, le recruteur devra informer le candidat qu'il souhaite conserver son dossier, afin de lui laisser la possibilité d'en demander la destruction. *Si un candidat ne demande pas la destruction de son dossier, les données sont automatiquement détruites 2 ans après le dernier contact. Seul l'accord formel du candidat permet une conservation plus longue.* *Doctrine de la CNIL*

Fichiers de gestion du personnel	Durée du contrat de travail

Fichiers de gestion du personnel	*Une fois l'employé parti, certaines informations peuvent être conservées par l'employeur sur un support séparé en archive (par exemple en cas de contentieux ou d'obligation légale)* Durée de prescription la plus longue en droit social

Conserver les données à caractère personnel pendant une durée limitée

Activités de traitement	Détails du traitement	Base active	Archivage intermédiaire	Textes de référence
Gestion de la paie	Bulletin de salaire	1 mois	5 ans	L. 3243-4 du code du travail
			50 ans en version dématérialisée	D. 3243-8 du code du travail
	Eléments nécessaires au calcul de l'assiette	1 mois	6 ans	L. 243-16 du code sécurité sociale
	Saisie des données calculées (DSN)	Le temps nécessaire à l'accomplissement de la déclaration	6 ans	L. 243-16 du code sécurité sociale
	Ordre de virement pour paiement	Le temps nécessaire à l'émission du bulletin de paie	10 ans à compter de la clôture de l'exercice comptable	L. 123-22 du code du commerce
Registre unique du personnel		La durée pendant laquelle le salarié fait partie des effectifs	5 ans à compter du départ du salarié de l'organisme	R. 1221-26 du code du travail

Analyse d'Impact (« Privacy Impact Assessment – PIA »)

Quand ? Obligatoire pour les traitements susceptibles d'engendrer un « risque élevé pour les droits et libertés », et en particulier s'il y a :

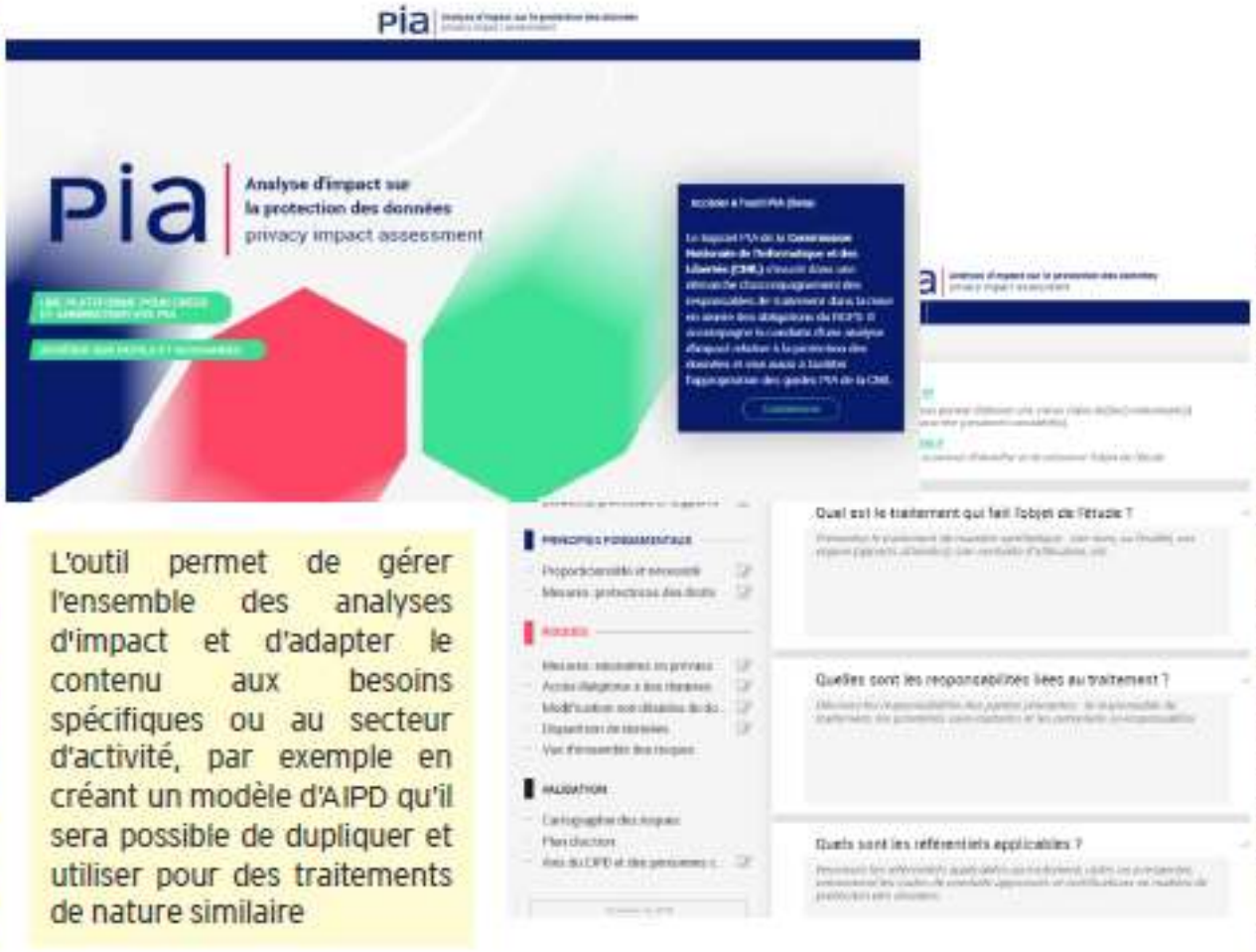
- Profilage
- Traitement à grande échelle de données sensibles
- Surveillance systématique et à grande échelle de zones accessibles au public

Par ailleurs, les autorités de protection des données (par ex. CNIL) peuvent déterminer les catégories de traitement nécessitant une étude d'impact.

Le cas échéant : Consultation de l'Autorité de protection des données obligatoire si l'analyse d'impact confirme un « risque élevé ».

Pour plus d'information:

- Cf. guides et listes du G29, de l'EDPB et de la CNIL
- Outil d'analyse d'impact de la CNIL



L'outil permet de gérer l'ensemble des analyses d'impact et d'adapter le contenu aux besoins spécifiques ou au secteur d'activité, par exemple en créant un modèle d'AIPD qu'il sera possible de dupliquer et utiliser pour des traitements de nature similaire

Privacy by Design et by Default

Privacy by Design

- **Conception** des services tenant compte du respect de la vie privée
- Respect du principe de minimisation des données et de limitation des finalités
- Haut standard de sécurité **depuis la conception**
- **Documentation** des mesures techniques et opérationnelles

Privacy by Default

- Mise en œuvre des mesures techniques et organisationnelles pour garantir que **par défaut**, seules les données personnelles nécessaires à la finalité du traitement sont traitées (ex. quantité, accès limité aux seules personnes y ayant intérêt, etc.)
- **Documentation** des mesures techniques et opérationnelles

Obligation de sécurité de traitement

- Obligation à la charge du Responsable du traitement et du sous-traitant
- Mise en œuvre des mesures techniques et organisationnelles appropriées pour garantir un niveau de sécurité adapté au risque

Critères d'appréciation des mesures

- Etat des connaissances et **coûts de mise en œuvre**
- **Nature, portée, contexte, finalité** du traitement
- **Risques présentés par le traitement** (degré de probabilité et de gravité) résultant de la destruction, perte, altération, divulgation, accès non autorisé aux données

Catégories de mesures

- **Pseudonymisation / chiffrement** des données
- **Moyens permettant de garantir la confidentialité** des systèmes de traitement…
- **Moyens permettant de rétablir la disponibilité / accès** aux données en cas d'incident physique ou technique
- Procédure **d'évaluation régulière des mesures de sécurité**

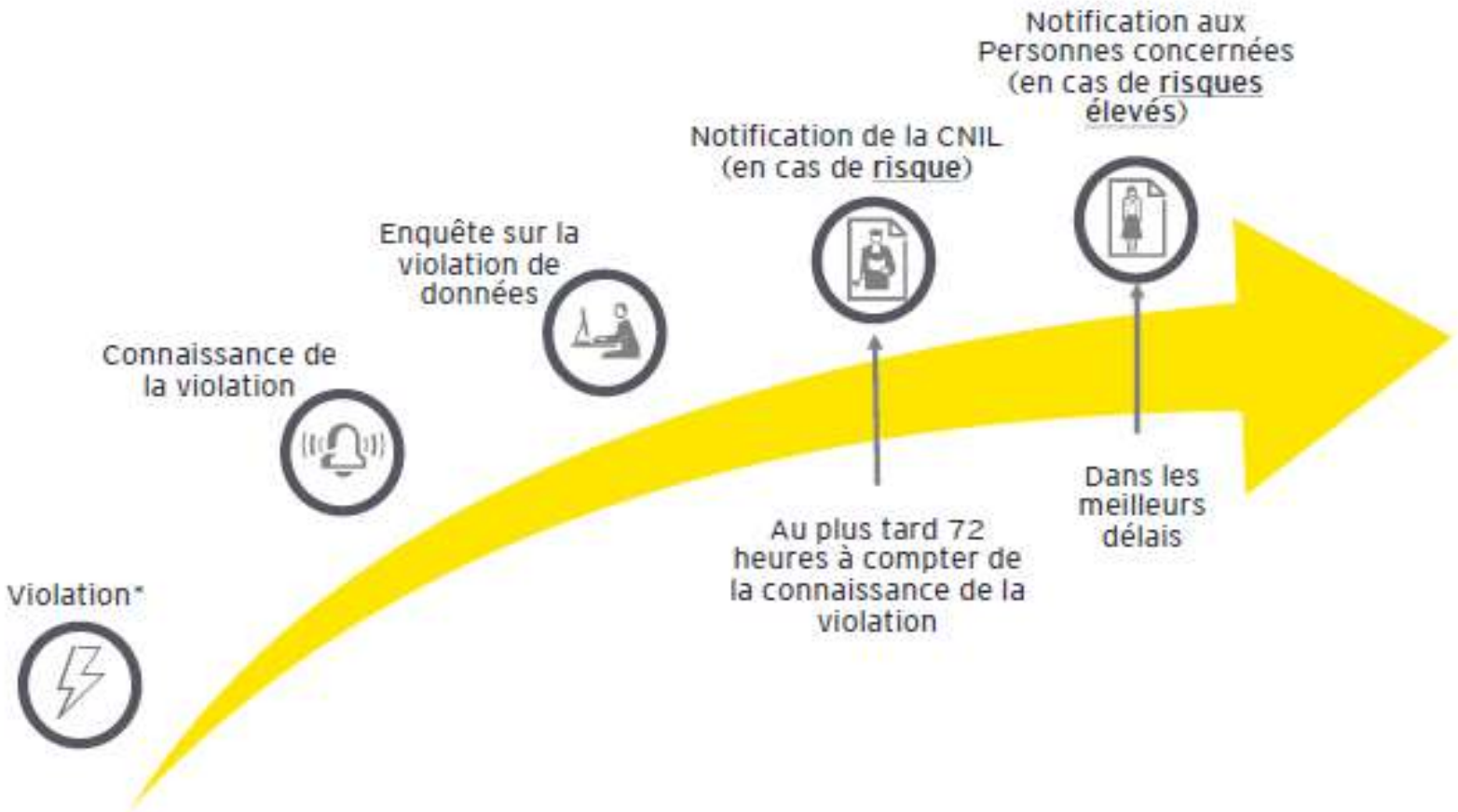
Pseudonymisation

- Les données ne peuvent plus être attribuées à un individu sans avoir recours à des informations supplémentaires conservées de manière séparée afin de garantir qu'il ne soit plus identifié ou identifiable
- RÉVERSIBLE

Anonymisation

- Technique consistant à supprimer tout caractère identifiant à un ensemble de données
- IRRÉVERSIBLE

Obligation de notification des violations de données personnelles



*«*Violation de données à caractère personnel*», une violation de la sécurité entraînant, de manière accidentelle ou illicite, la destruction, la perte, l'altération, la divulgation non autorisée de données à caractère personnel transmises, conservées ou traitées d'une autre manière, ou l'accès non autorisé à de telles données

PRINCIPE → Obligation de notifier les violations

- → Auprès de la CNIL dans un délai de 72 heures en cas de risque pour les droits et libertés de la Personne concernée
- → Auprès des Personnes concernées en cas de risque élevé pour leurs droits et libertés sauf dans certains cas (ex. la notification impliquerait un effort disproportionné. Dans ce cas, il y a lieu de procéder à une communication publique ou à une mesure similaire)
- → Obligation du Sous-traitant d'informer le Responsable du traitement en cas de violation

Obligation de notification des violations de données personnelles

Informations à fournir à la CNIL :

- La nature de la violation
- Si possible, les catégories et le nombre approximatif de personnes concernées par la violation
- Les catégories et le nombre approximatif d'enregistrements de données à caractère personnel concernés;
- Les conséquences probables de la violation de données ;
- Les mesures prises ou que vous envisagez de prendre pour éviter que cet incident se reproduise ou atténuer les éventuelles conséquences négatives.

Obligation de notification des violations de données personnelles

https://notifications.cnil.fr/notifications/index

Type de notification

Les champs en caractères gras sont obligatoires

TYPE DE NOTIFICATION

ALERTE INFO : veuillez indiquer si votre notification est liée au cas suivant :

☑ Oui, ma notification (initiale, complémentaire ou complète) est liée à l'indisponibilité des **services du CIG Grande Couronne**.

Précisez si vous allez effectuer une notification complète, une notification initiale qui sera complétée ultérieurement ou si vous souhaitez compléter ou amender une notification déjà réalisée

- ○ Notification complète
- ○ Notification initiale
- ○ Notification complémentaire / modifiée

Obligation de notification des violations de données personnelles

FOCUS sur l'hébergement des données de santé :

Article L. 1111-8 du Code de la santé publique :

« Toute personne qui héberge des données de santé à caractère personnel recueillies à l'occasion d'activités de prévention, de diagnostic, de soins ou de suivi médico-social pour le compte de personnes physiques ou morales à l'origine de la production ou du recueil de ces données ou pour le compte du patient lui-même, réalise cet hébergement dans les conditions prévues au présent article ».

L'hébergeur de données sur support numérique doit être titulaire d'un certificat de conformité, délivré par des organismes de certification accrédités.

- **Obligation de vérifier que le prestataire d'hébergement est certifié « HDS »** (ou qu'il travaille avec un partenaire hébergeur certifié HDS)

Certification « HDS » = Hébergeur de Données de Santé (avant Juin 2018 : agrément HDS)

Exceptions ?

L'obligation de recourir à un prestataire détenteur de la certification ne s'applique pas pour :

- **Les organismes de recherche** à condition que les bases de données utilisées n'aient pas été constituées à l'origine pour répondre à des besoins de prévention, de diagnostic, de soin ou de suivi social et/ou médico-social
- **Les organismes d'assurance maladie**
- **Les associations** proposant des activités sportives à des personnes handicapées
- **Les services d'archivages informatiques**

Régime des transferts internationaux

- Restriction des transferts de données hors de l'Union Européenne
- Le RGPD autorise les transferts de données vers des pays dont le régime fournit un **niveau adéquat de protection des données personnelles.**
- A défaut, il faut des **garanties adéquates**

Un transfert de données hors de l'Union européenne ne nécessite pas matériellement l'envoi de données en tant que tel. L'hébergement de données sur des serveurs situés en dehors de l'Union européenne peut constituer un transfert hors de l'Union européenne.

Par ex. : Une société française collecte les données des internautes pour l'envoi d'une newsletter. Les envois sont gérés par le biais de la solution web **MailChimp.**

Puisque l'éditeur de la solution MailChimp est basé aux Etats-Unis et utilise des serveurs en dehors de l'UE, les données (adresses électroniques notamment) sont transférées en dehors de l'UE

Régime des transferts internationaux

Un plan d'action en 6 étapes à suivre (cf. Recommandations CEPD 01/2020 sur les mesures supplémentaires à mettre en place pour assurer un niveau de protection adéquat des données personnelles)

Etape 1

Cartographie des transferts

- Contrats
- Registre des traitements
- ...

Etape 2

Vérifier le mécanisme de transferts

- CCT
- BCR
- Clauses Ad'hoc
- Décision d'adéquation (arrêt de la revue)
- Exception (arrêt de la revue)

Etape 3

Evaluer le niveau de protection du pays tiers

- « *European Essential Guarantees recommandations* » du CEPD
- Par ex. condition d'accès aux données aux autorités publiques

Etape 4

Déterminer les mesures supplémentaires à mettre en place

- Meures supplémentaires techniques, organisationnelles ou contractuelles.
- Par exemple : chiffrement (clés détenues par l'exportateur)

Etape 5

Mettre en place les mesures supplémentaires identifiées

- Plan d'action
- Description des mesures
- Identification des personnes en charge de l'implémentation

Etape 6

Ré-évaluer à intervalle régulier

- Suivre et procéder à une évaluation notamment en cas d'évolution dans les pays tiers susceptible d'affecter l'évaluation, etc.

Régime des transferts internationaux

Décision d'adéquation :

Lorsque la Commission a constaté qu'un pays tiers assure un niveau de protection adéquat.

- Jersey
- Guernesey
- L'Île de Man
- Les îles Féroé
- L'Argentine
- Andorre
- La Nouvelle-Zélande
- L'Uruguay
- La Suisse
- Le Liechtenstein
- L'Islande
- Israël
- Le Canada
- Le Japon
- La Corée du Sud
- Le Royaume - Uni

Régime des transferts internationaux

Garanties adéquates

- Instrument juridiquement contraignant et exécutoire entre les autorités ou organismes publics
- *Binding Corporate Rules* («BCR»)
- Clauses contractuelles standard adoptées par la Commission européenne
- Clauses contractuelles standard adoptées par une autorité de contrôle et approuvées par la Commission
- Code de conduite approuvé
- Mécanisme de certification
- Dérogations limitées (consentement, exécution d'un contrat…)

Régime des transferts internationaux

La CJUE dans son arrêt du 16 juillet 2020 :

INVALIDE le "Privacy Shield"

La loi américaine ne prévoit pas :

- Les limitations et les garanties nécessaires ;
- Une protection judiciaire efficace contre les programmes de surveillance américains ;
- Un recours devant un organe disposant de garanties substantiellement équivalentes à celles requises par le droit de l'Union (notamment en termes d'indépendance vis-à-vis des autorités publiques américaines). Le mécanisme de médiation prévu par le Privacy Shield n'est pas suffisant.

VALIDE les CCT

La CJUE a validé le recours aux clauses contractuelles types, tout en soulignant la nécessité de veiller à ce que des mécanismes efficaces soient mis en place pour assurer le respect d'un niveau de protection adéquat et équivalent à celui accordé par le RGPD.

Décision d'adéquation de la Commission européenne du 10 juillet 2023 en application de l'article 45 du RGPD:

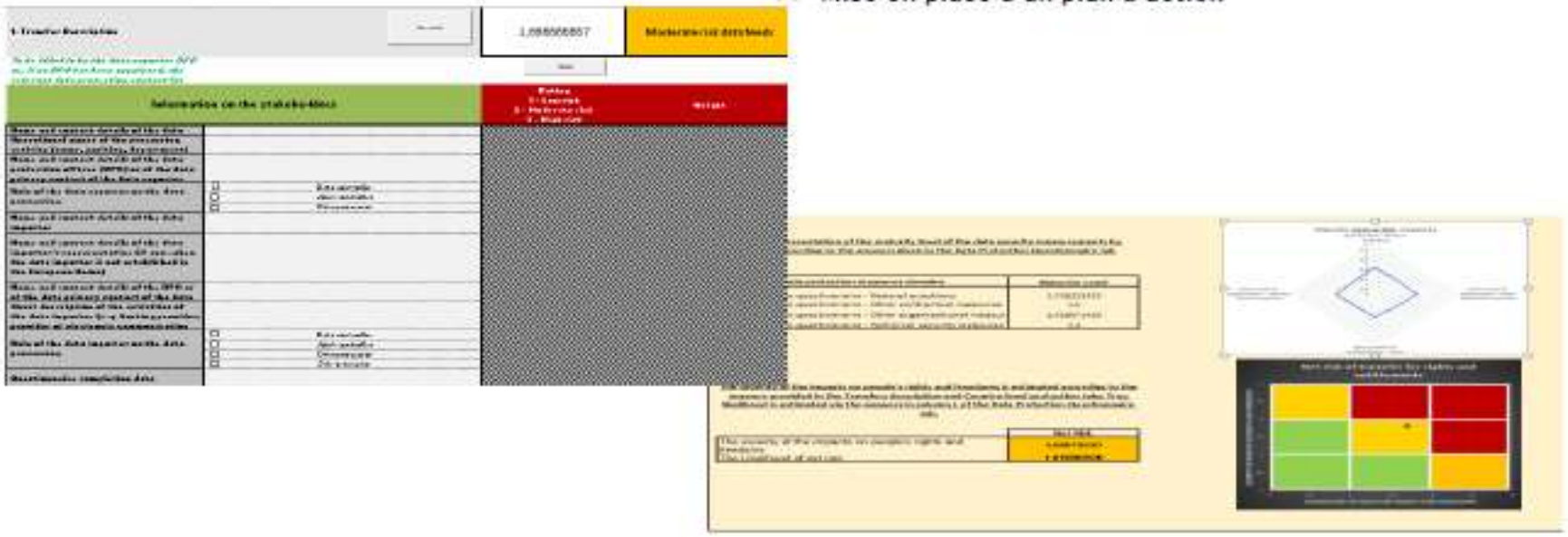
- La liste des organisations américaines faisant la démarche de respecter le « EU-US Data Privacy Framework » est publiée par le ministère américain du commerce: https://www.dataprivacyframework.gov/s/participant-search

Régime des transferts internationaux

"Transfer Impact Assessment tool"

- <u>Objectif:</u> Réaliser l'évaluation de leurs transferts vers les pays tiers « post-Schrems II »
- Prendre en compte les *recommandations du CEPD 01/2020 sur les mesures supplémentaires à mettre en place*

1. Description des transferts
2. Identification des mécanismes encadrant les transferts
3. Niveau de protection du pays tiers
4. Questionnaire relatif à la protection des données y incluant :
   - Mesures de sécurité technique, contractuelles et organisationnelles
5. Risques du transfert (initial et résiduel)
6. Mesures complémentaires et actions à mettre en œuvre
7. Mise en place d'un plan d'action



Information des personnes concernées

Contenu de l'information

- Mentions d'information obligatoires :
  - Vis-à-vis des visiteurs, exposants
  - Vis-à-vis des collaborateurs/salariés
  - Vis-à-vis des candidats au recrutement
  - Vis à vis des utilisateurs du site Internet (si collecte des données sur le site Internet)
  - Vis-à-vis de plus généralement de tous contacts personnes physiques dont les données seraient traitées (prospects, fournisseurs, relations professionnelles, visiteurs, etc.)

- Quelles informations ?

Information des personnes concernées

Modalités d'information des personnes concernées

1er niveau d'information

Afin de fournir des informations aux personnes concernées, le responsable du traitement doit fournir un minimum d'informations au moment de la collecte des données à caractère personnel (par exemple, formulaire de contact, ...) :

- Identité du responsable du traitement
- Détails des finalités du traitement
- Droits de la personne concernée (accès, etc.)

2ème niveau d'information

Le 1er niveau d'informations doit être lié à la politique de confidentialité complète pour fournir des informations supplémentaires et complètes sur le traitement à la personne concernée conformément à l'article 13 du RGPD.

Niveau 1 de l'information (sur le questionnaire)

Niveau 2 de l'information (sur la notice jointe au questionnaire)

[Le responsable de traitement] traite les données recueillies pour **[finalités du traitement]**.

Pour en savoir plus sur la gestion de vos données personnelles et pour exercer vos droits, reportez-vous à la notice ci-jointe.

N.B : distinguer dans le formulaire de collecte, par exemple via des astérisques, les données dont la fourniture est obligatoire de celles dont la fourniture est facultative

Niveau 1 de l'information (sur le questionnaire)

Niveau 2 de l'information (sur la notice jointe au questionnaire) :

Les informations recueillies dans le questionnaire sont enregistrées dans un fichier informatisé par **[coordonnées du responsable de traitement]**. La base légale du traitement est **[base légale du traitement]**.

Les données marquées par un astérisque dans le questionnaire doivent obligatoirement être fournies. Dans le cas contraire, **[préciser les conséquences éventuelles en cas de non-fourniture des données]**.

Les données collectées seront communiquées aux seuls destinataires suivants : **[destinataires des données]**.

Elles sont conservées pendant **[durée de conservation des données prévue par le responsable du traitement ou critères permettant de la déterminer]**.

Vous pouvez accéder aux données vous concernant, les rectifier, demander leur effacement ou exercer votre droit à la limitation du traitement de vos données. **(en fonction de la base légale du traitement, mentionner également : Vous pouvez retirer à tout moment votre consentement au traitement de vos données ; Vous pouvez également vous opposer au traitement de vos données ; Vous pouvez également exercer votre droit à la portabilité de vos données)**

Consultez le site cnil.fr pour plus d'informations sur vos droits.

Pour exercer ces droits ou pour toute question sur le traitement de vos données dans ce dispositif, vous pouvez contacter **(le cas échéant, notre délégué à la protection des données ou le service chargé de l'exercice de ces droits) : [adresse électronique, postale, coordonnées téléphoniques, etc.]**

Si vous estimez, après nous avoir contactés, que vos droits « Informatique et Libertés » ne sont pas respectés, vous pouvez adresser une réclamation à la CNIL.

Droit des personnes concernées

Information des personnes concernées

- Le Principe : les Personnes concernées doivent recevoir une information détaillée sur le traitement et en amont de la mise en œuvre de celui-ci
- Quelques exceptions : ex. si la Personne concernée dispose déjà de ces informations
- Le RGPD impose de fournir des informations supplémentaires aux Personnes concernées : informations de contact et identité du DPO, base légale du traitement, intérêt légitime, droit de retirer son consentement, existence de finalités ultérieures, etc.

Consentement

- **Une définition du consentement précisée :** « *une manifestation de volonté, libre, spécifique, éclairée et univoque par laquelle la personne concernée accepte, par une déclaration ou par un acte positif clair, que des données à caractère personnel la concernant fassent l'objet d'un traitement* » (Article 4 du RGPD)

Quand le consentement peut-il être nécessaire ?

Quelques exemples:

- Base de licéité du traitement
- Catégories spéciales de données
- Prospection commerciale

Doctrine de la CNIL dans la sphère de la relation de travail (lien de subordination employeur/employé)

Droit des personnes concernées

Droit d'accès

Précision de ce droit qui donne la possibilité :

- D'obtenir confirmation que leurs données sont traitées
- D'obtenir communication de ses données personnelles (copie)

Droit d'opposition

Renforcement de ce droit (ex.) :

- Pour des raisons tenant à sa « **situation particulière** » par ex. pour les traitements reposant sur l'intérêt legitime du RT
- **Sans motif pour la prospection commerciale**

Droit de rectification

Possibilité pour les Personnes concernées de faire **rectifier leurs données** si elles sont **inexactes ou incomplètes**

Délais très courts (**1 mois** à compter de la réception de la demande et au besoin **prolongé de 2 mois** (ex. demande complexe))

Droit des personnes concernées : nouveaux droits issus du RGPD

Décision fondée exclusivement sur un traitement automatisé

- Droit d'opposition à ce qu'une Personne concernée fasse l'objet d'une décision fondée exclusivement sur un traitement automatisé, y compris le profilage, produisant des effets juridiques la concernant ou l'affectant de manière significative de façon similaire
- Exception : la décision est nécessaire à la conclusion ou à l'exécution d'un contrat ou est autorisée par le Droit de l'UE ou français ou la Personne concernée a donné son consentement explicite

DROIT À L'EFFACEMENT (DROIT À L'OUBLI)

- Droit d'obtenir l'effacement de ses données dans les meilleurs délais
- Conditions : données plus nécessaires, retrait du consentement, opposition au traitement…
- Exceptions : liberté d'expression et d'information, obligation légale…

DROIT À LA LIMITATION DU TRAITEMENT

- Contestation exactitude des données
- Traitement illicite et la personne préfère une limitation à un effacement
- Conséquence: les données ne peuvent plus être traitées sauf consentement ou pour l'exercice d'un droit en justice (etc.)

DROIT À LA PORTABILITÉ DES DONNÉES

- Extension du droit d'accès
- Interopérabilité (format structuré, couramment utilisé et lisible par machine)
- Transfert (à un autre Responsable de traitement)
- Restrictions (traitement automatisés, bases de licéité limitées,…)

3 - La protection des données et Les actions à conduire en entreprise

Les enjeux de la gestion des données et de l'IA en Entreprise

- **Limites et enjeux**
- Malgré les avancées législatives, plusieurs limites et défis subsistent. **La rapidité de l'évolution technologique rend difficile l'adaptation des cadres juridiques, qui peuvent rapidement devenir obsolètes**. **L'harmonisation internationale des régulations est également complexe**, chaque pays ou région ayant ses propres priorités et sensibilités

- **Les enjeux majeurs comprennent** :

• **Un équilibre entre innovation et protection : trouver le juste milieu entre encourager l'innovation technologique et assurer la protection des droits fondamentaux est un défi de taille**

• **Une gestion des biais et de l'éthique :** les systèmes d'IA peuvent reproduire ou amplifier des **biais existants**. Il est crucial de développer des **méthodes pour identifier et corriger ces biais afin de garantir une justice algorithmique**

• **La transparence et explicabilité :** les **algorithmes d'IA sont souvent opaques**. Promouvoir la **transparence et l'explicabilité des systèmes est essentiel pour instaurer la confiance des utilisateurs** et faciliter le contrôle réglementaire

• **Une formation et sensibilisation aux risques : les entreprises et les individus doivent être formés aux enjeux de l'IA pour une utilisation responsable et éclairée**. La **sensibilisation est indispensable pour prévenir les dérives potentielles**

Les données - L’IA et le droit de la propriété intellectuelle

- **<u>Les textes clés liés à l’IA interférant avec le droit de la propriété intellectuelle et en particulier le droit propriété littéraire et artistique</u>**
- Règlement 2024/1689 du 13 juin 2024 sur l’intelligence artificielle « IA Act »

➔ Règlement (UE) 2024/1689 du Parlement européen et du Conseil du 13 juin 2024 établissant des règles harmonisées concernant l’intelligence artificielle et modifiant les règlements (CE) n° 300/2008, (UE) n° 167/2013, (UE) n° 168/2013, (UE) 2018/858, (UE) 2018/1139 et (UE) 2019/2144 et les directives 2014/90/UE, (UE) 2016/797 et (UE) 2020/1828 (règlement sur l’intelligence artificielle) (Texte présentant de l'intérêt pour l'EEE)

- **Proposition de loi n°1630 visant à encadrer l’intelligence artificielle par le droit d’auteur déposée le mardi 12 septembre 2023**
- Directive 2019/790 du 17 avril 2019 sur le droit d’auteur et les droits voisins
- Ordonnance n° 2021-1518 du 24 novembre 2021 complétant la transposition de la directive

Les données - L'IA et le Droit – Les actions à conduire en entreprise

- Les actions à conduire sont **le plus souvent basiques** et n'engagent ni le quotidien, ni l'organisation du travail, le plus souvent…
- Elles peuvent être **mises en œuvre sur la base** de ce que l'entreprise, le plus souvent, **possède déjà, en termes de sources particulièrement**
- Par contre la protection des intérêts de l'entreprise implique que les **sources** soient **lues et exploitées** et fassent l'objet de la **« curiosité professionnelle »** nécessaire par les personnes en charges de ces questions (Responsable de traitement, DPO ou Sce achats, RH, Méthodes….) vis-à-vis notamment de **l'extérieur**
- En **interne**, les différents textes, qui **traitent soit des données soit de l'IA, soit des deux**, notamment, doivent être mis en **interrelation** de façon à **générer la cohérence nécessaire** dans les conduites recherchées

Quel cadre en interne?

Points d'attention / encadrement de l'utilisation par les collaborateurs

- **Encadrer l'utilisation des outils d'IA au sein de l'entreprise :** prévoir des règles d'utilisation pour les collaborateurs via une charte d'usage de l'IA (ou tout autre document dédié)
  - **Rappeler aux salariés leurs obligations** au regard des exigences règlementaires (ex. protection des données personnelles) et vis-à-vis de leur employeur (préservation du secret d'affaires etc.);
  - **Interdire certains comportements** susceptibles de générer des risques en termes de sécurité et de confidentialité ou des comportements attentatoires aux droits d'autrui (ex. utilisation d'outils permettant de commettre des atteintes en matière de PI, des actes de discrimination etc.) ;
  - **S'assurer de la force contraignante de la charte** en lui associant un impact disciplinaire / en prévoyant des sanctions en cas de non-respect ;
  - **Organiser la responsabilité** entre le salarié et l'employeur quand le matériel ayant servi à un comportement délictueux a été mis à la disposition par l'employeur;
  - **Organiser des délégations de pouvoir** en interne vers les principaux responsables opérationnels en charge des SIA ;
- **Entamer une négociation** avec les partenaires sociaux sur le bon usage de l'IA

Articulation RGPD et IA

Fiches pratiques de la CNIL	Précisions
Déterminer sa qualité en tant qu'acteur impliqué dans l'utilisation d'un SIA	Responsable de traitement, responsable conjoint, sous-traitant…
Réaliser une AIPD pour cartographier et évaluer les risques des traitements induits par l'utilisation d'un SIA	Un des critères déterminant la nécessité de réaliser une AIPD est *« l'utilisation innovante ou l'application de nouvelles solutions technologiques ou organisationnelles »*
Mettre à jour sa documentation	Registre des traitements, Charte informatique, Mentions d'information,…
Sécuriser l'utilisation du SIA par la mise en œuvre de mesures techniques et organisationnelles	Restreindre les accès (mots de passe), restreindre les informations pouvant être renseignées dans le SIA,…
Editer un code de bonne conduite	Règles à respecter par les utilisateurs
Limiter l'usage du SIA aux besoins prédéfinis	Paramétrer si possible le système pour empêcher certaines requêtes avec un risque
Vérifier la qualité du SIA	Certains SIA (notamment les SIA à haut risque) feront l'objet d'un marquage « CE » qui garantira leur conformité
Examiner l'existence de transfert de données à l'étranger	En particulier si les données ne sont pas hébergées par le déployeur mais par le fournisseur du SIA

Le Droit du numérique et de la PI, IA et des données – Les sources

- Bibliographie :

- Droit de l’intelligence artificielle – Sabine Marcellin - éd. Gualino Lextenso
- La guerre des intelligences à l’heure de Chat GPT – Dr Laurent Alexandre - éd. JC Lattès
- L’intelligence artificielle pour les nuls – John Paul Mueller Luca Massaron – éd. Pour les nuls
- Un droit de l’intelligence artificielle – Céline Castets-Renard et Jessica Eynard – éd. Bruylant
- An executive’s guide to AI – Livre Blanc EY
- Droit du numérique – Me Maël FABLET Avocat associé – Séminaire mai 2025 – Sté d’Avocats EY
- L’essentiel du Droit du numérique - collection carré – Amélie FAVREAU - Editeur Gualino Lextenso
- Le risque Cyber – Véronique CHANUT, Cédric DENIS-REMIS, Aude DEVILLE – Editions EMS

MERCI

UNIVERSITÉ SAVOIE MONT BLANC

tétras

CSM HAUTE-SAVOIE